

Care Access Navigator

Cyber Threat Analysis Report — Malware & Phishing Simulation | HealthLine Regional Medical Center (HRMC)

Status: SIMULATED / DRAFT | **Course Rubric:** Malware Analysis & MITRE ATT&CK Mapping | **Capstone**

Week: Week 2 (supplemental exercise)

IN PLAIN TERMS

A workstation at HRMC was infected with malware (aKQE.exe, AgentTesla family) that installs itself to auto-start every time the computer boots, injects itself into a trusted Windows process to dig out saved passwords, and then quietly emails everything it steals to an attacker-controlled mail server (smtp.hostinger.com) — all without the user seeing anything unusual. The malware profile below uses real sandbox/detection data pulled from VirusTotal for a real, publicly catalogued sample; the hospital, asset, and incident framing are simulated for coursework.

1. Incident Summary

Field	Detail
Incident ID	INC-W2-001 (simulated)
Date/Time Detected (simulated)	Week 2, Day 4 — <fill from your test timeline>
Reporting Source	Endpoint EDR alert + SIEM correlation (simulated)
Malware Family	AgentTesla (MSIL-based keylogger / infostealer)
Sample Hash (SHA256)	1c72369e2543722e89be3a14448d0fdc1664f4638d91d67720dddb7ff73cb736
VirusTotal Detection Ratio	34 / 70
Classification	Commodity infostealer / credential harvester

2. Affected Asset (Simulated Mapping)

Field	Detail
Asset ID	AST-03 (<i>adjust to match your asset inventory</i>)
Asset Type	Workforce endpoint (Windows workstation)
Department	Patient Registration / Billing (<i>adjust to fit your AST-## entry</i>)
Data Sensitivity	ePHI-adjacent — endpoint has access to Billing App and shares a network segment with systems processing ePHI

3. Malware Profile

AgentTesla is a long-running, widely distributed .NET-based infostealer/keylogger, commonly delivered via phishing attachments (macro-enabled Office documents, or malicious archive/executable attachments) — the same delivery path already simulated in the Part 2 SEToolkit exercise, giving this incident a coherent phishing-to-infection chain.

Documented capabilities (publicly established behavior for this family):

- Keystroke logging
- Credential harvesting from browsers, email clients (Outlook), and FTP clients
- Clipboard monitoring
- Screenshot capture
- Exfiltration via SMTP email, FTP, Telegram Bot API, or HTTP-based C2 panels (varies by build)

4. Technical Behavior (Simulated Detonation Findings)

Fields below should be completed from the sample's actual VirusTotal Behavior / Relations tabs. Structure reflects typical AgentTesla behavior for reference.

Category	Finding
Sandbox verdicts	Flagged MALWARE by CAPE Sandbox and Yomi Hunter; flagged STEALER by C2AE
Observed file name	aKQE.exe (1.04 MB, PE/.NET executable)
Process injection	Process Injection (T1055) observed 8 times; Crowdsourced Sigma rule "Unsigned Image Loaded Into LSASS Process" matched — consistent with AgentTesla's typical credential-dumping injection into a legitimate process targeting LSASS memory
Persistence mechanism	Registry Run Keys / Startup Folder (T1060) and Modify Registry (T1112, x5); Sigma rules "CurrentVersion Autorun Keys Modification" and "Suspicious PowerShell In Registry Run Keys" matched — consistent with an HKCU ...Run autostart key
Reconnaissance behavior	GET http://ip-api.com/line/?fields=hosting — queries external IP/hosting-provider lookup service prior to exfiltration (flagged by Sigma rule "Suspicious DNS Query for IP Lookup Service APIs" and IDS rule "ET INFO External IP Lookup Domain in DNS Lookup")
Exfiltration channel	SMTP — outbound TCP connection to smtp.hostinger.com on port 587 (mail submission port), matching AgentTesla's classic SMTP-based credential exfiltration method
Contacted C2/exfil domain	smtp.hostinger.com → resolved to TCP 172.65.255.143:587
Secondary contacted host	ip-api.com → resolved to TCP 208.95.112.1:80 (IP/geolocation recon service, not attacker-controlled)
Credential access behavior	OS Credential Dumping (T1003) and Unsecured Credentials (T1552) both observed — matches AgentTesla's core credential-harvesting function
Defense evasion	Obfuscated Files or Information (T1027, x3); Indirect Command Execution (T1202)
JA3 TLS fingerprint	3b5074b1b5d032e5620f69f9f700ff0e
IDS rule match (highest severity)	HIGH — "ET MALWARE Common Stealer Behavior - Source IP Associated with Hosting Provider Check via ip-api.com" (Proofpoint Emerging Threats Open) — classified as "A Network Trojan was detected"

5. Indicators of Compromise (IOCs)

Type	Value
SHA256	1c72369e2543722e89be3a14448d0fdc1664f4638d91d67720dddb7ff73cb736
Family	AgentTesla
File name	aKQE.exe
Exfil domain (SMTP)	smtp.hostinger.com (172.65.255.143:587)
Recon domain (IP lookup)	ip-api.com (208.95.112.1:80)
JA3 fingerprint	3b5074b1b5d032e5620f69f9f700ff0e
Persistence artifact	HKCU Registry Run key (autostart entry) — confirmed via Sigma rule "CurrentVersion Autorun Keys Modification"

6. Impact to HRMC (Simulated)

Confidentiality impact: Stolen local credentials could enable follow-on lateral movement toward systems holding ePHI, directly relevant to the project's ePHI boundary rules.

Risk register linkage: Maps to an existing endpoint-compromise entry in the risk register (R-##) if one is already defined; if not yet captured, this incident supports adding a new risk entry for “credential theft via endpoint malware.”

Control objective linkage: Ties to the control objective(s) (CO-##) covering endpoint protection/EDR, and to the IAM control set — MFA reduces the value of stolen static credentials, tying back directly to the Keycloak MFA configuration.

7. Response Actions (Simulated / Planned)

1. Isolate affected endpoint from network (VLAN 30 quarantine).
2. Force credential reset for any accounts used on that workstation, prioritizing accounts with access to ePHI systems.
3. Review SIEM logs for the exfil domain/IP to check for other affected hosts.
4. Submit hash/IOC to threat intel feed for organizational blocklist update.

8. MITRE ATT&CK Technique Mapping

Confirmed via VirusTotal auto-detection (this sample, live sandbox data):

Technique	ATT&CK; ID	Tactic
Windows Management Instrumentation	T1047	Execution
Command and Scripting Interpreter	T1059	Execution
Native API	T1106	Execution
New Service	T1050	Persistence / Privilege Escalation
Registry Run Keys / Startup Folder	T1060	Persistence
Modify Registry	T1112	Persistence
Process Injection	T1055	Privilege Escalation / Defense Evasion
Create or Modify System Process	T1543	Privilege Escalation
Obfuscated Files or Information	T1027	Defense Evasion
Indirect Command Execution	T1202	Defense Evasion
OS Credential Dumping	T1003	Credential Access
Unsecured Credentials	T1552	Credential Access

Delivery-chain techniques (from Part 2 phishing simulation, not sample-specific):

Technique	ATT&CK; ID	Tactic
Phishing	T1566	Initial Access

Technique	ATT&CK; ID	Tactic
Exfiltration Over Alternative Protocol (SMTP)	T1048	Exfiltration

This table feeds directly into Part 3 APT group research — cross-reference these techniques against candidate Groups' technique lists on the ATT&CK Enterprise matrix to identify which documented threat actor(s) align with the observed behavior chain.

9. Phishing Simulation (SEToolkit Credential Harvester)

IN PLAIN TERMS

A fake sign-in page was set up in the lab and a test user's browser was pointed at it. The moment the test account typed a username and password into the fake page, the tool running in the background captured both values instantly — showing exactly how an employee at HRMC could unknowingly hand over their login credentials to an attacker.

Field	Detail
Tool	Social-Engineer Toolkit (SET), Website Attack Vectors → Credential Harvester
Method	Web Templates (built-in static template #2 — Google-styled sign-in page); no live site was cloned or contacted
Listener	Credential Harvester served on port 80, attacker host (Kali VM)
Target/victim host (simulated)	10.11.2.130 — simulated HRMC workstation on the lab network
Captured request	POST /ServiceLoginAuth → HTTP 302 (harvester logged submission, then redirected the victim as if login succeeded)
Harvested fields	Username field (Email) and Password field (Passwd) both captured in plaintext from the POST body, using synthetic/test credentials only
Outcome	Demonstrates that a convincingly-branded fake login page can silently capture credentials with no visible failure to the victim, since the harvester redirects to the real site after capture

Relevance to HRMC: This is the delivery vector that would precede the AgentTesla infection documented in Section 3 — an HRMC staff member receiving a convincing lookalike login page (e.g. spoofing a portal or email provider) could have credentials harvested directly, or be led to download and execute a malicious attachment/link that deploys the malware analyzed above. Together, these two simulations demonstrate both the credential-phishing and malware-delivery variants of the same initial-access technique.

MITRE ATT&CK mapping for this simulation:

Technique	ATT&CK; ID	Tactic
Phishing: Spearphishing Link	T1566.002	Initial Access
User Execution: Malicious Link	T1204.001	Execution
Credentials from Password Stores (victim-side capture analog)	T1555	Credential Access

10. APT Campaign / Threat Group Mapping

IN PLAIN TERMS

Two real, MITRE-documented hacker groups were researched to see who this kind of attack looks like in the real world. One group is directly tied to the exact malware used in this incident. The other doesn't use this specific malware, but has spent a decade attacking hospitals and healthcare companies specifically — which is exactly the kind of organization HRMC is, and helps explain why this incident matters.

10.1 Technique-Linked Group: SilverTerrier (G0083)

Field	Detail
ATT&CK; ID	G0083
Link to this incident	MITRE ATT&CK;'s official Software page for AgentTesla (S0331) lists SilverTerrier as the only documented Group using this exact malware family
Profile	A cluster of Nigeria-based business email compromise (BEC) threat actors active since at least 2014, using commodity RATs/keyloggers (including AgentTesla) delivered via phishing to compromise business email accounts and redirect wire transfers or invoices
TTP overlap with this incident	Phishing-based initial access, credential harvesting, and use of AgentTesla as the deployed tool — a direct, sourced match to the sample analyzed in Section 3

10.2 Sector-Relevant Group: Orangeworm (G0071)

Field	Detail
ATT&CK; ID	G0071
Link to this incident	Not a malware match — Orangeworm uses its own backdoor (Kwampirs, S0236), not AgentTesla. Included because it is the MITRE-documented group most specifically associated with healthcare-sector targeting, establishing why HRMC is a plausible target for this class of attack
Profile	Active since at least 2015, targeting healthcare providers, pharmaceutical companies, and healthcare IT/device supply chain across the US, Europe, and Asia, primarily for corporate espionage. Roughly 40% of victims are healthcare providers directly; the remainder are supply-chain partners used to reach hospital networks
Notable targeting detail	Their Kwampirs backdoor has been found specifically on machines running software for imaging equipment (X-ray/MRI) and on systems used for patient consent forms — directly analogous to HRMC's clinical and patient-facing systems
Documented techniques	Application Layer Protocol: Web Protocols (T1071.001) for HTTP-based C2; Remote Services: SMB/Windows Admin Shares (T1021.002) for lateral movement by copying the backdoor across network shares

Combined assessment for HRMC: The AgentTesla incident demonstrates the credential-theft, phishing-driven compromise pattern documented for SilverTerrier. Independently, Orangeworm's sustained, healthcare-specific

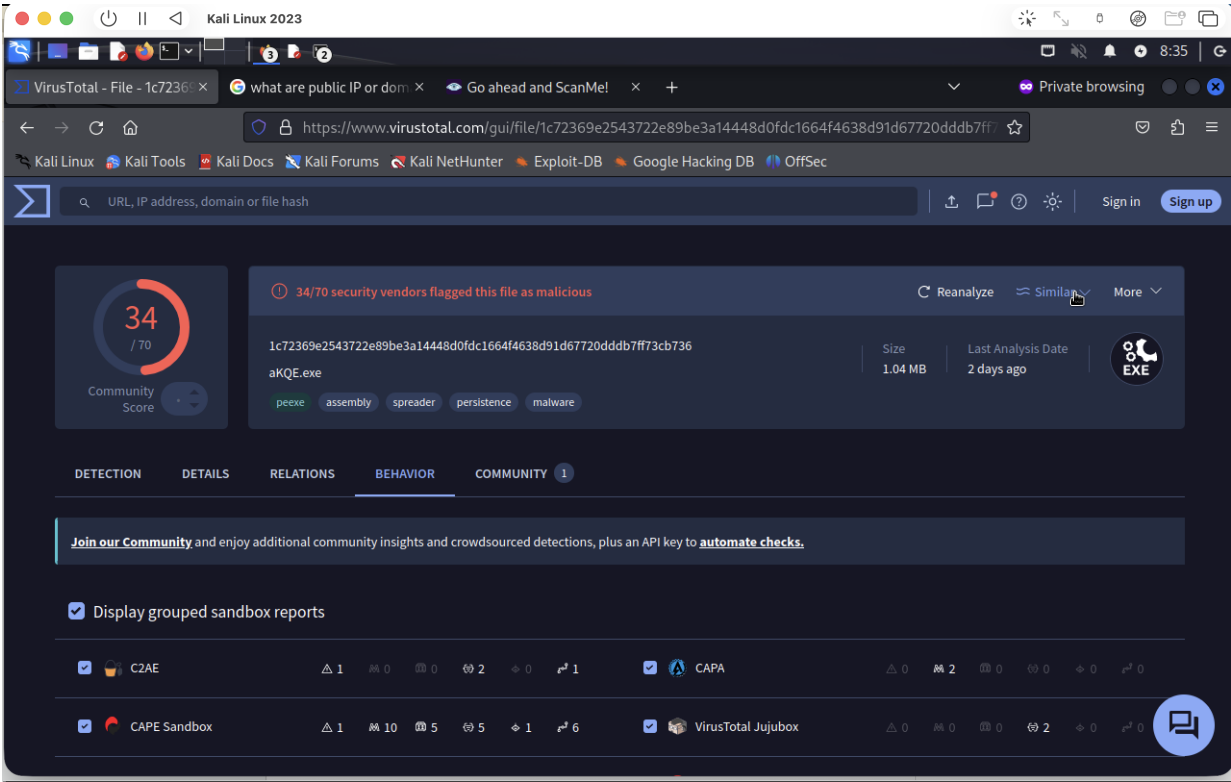
targeting confirms that hospitals and healthcare supply chains are an active, real-world target category for this general class of intrusion — reinforcing that HRMC's IAM and endpoint controls (MFA, RBAC, EDR) are addressing a genuine, documented threat rather than a hypothetical one.

Prepared as part of the Care Access Navigator IAM & GRC Healthcare Cybersecurity Capstone. All hospital details, asset IDs, and incident data are simulated/synthetic for coursework purposes. Sample hash and detection ratio reference a real, publicly catalogued malware sample used solely as a technical grounding point.

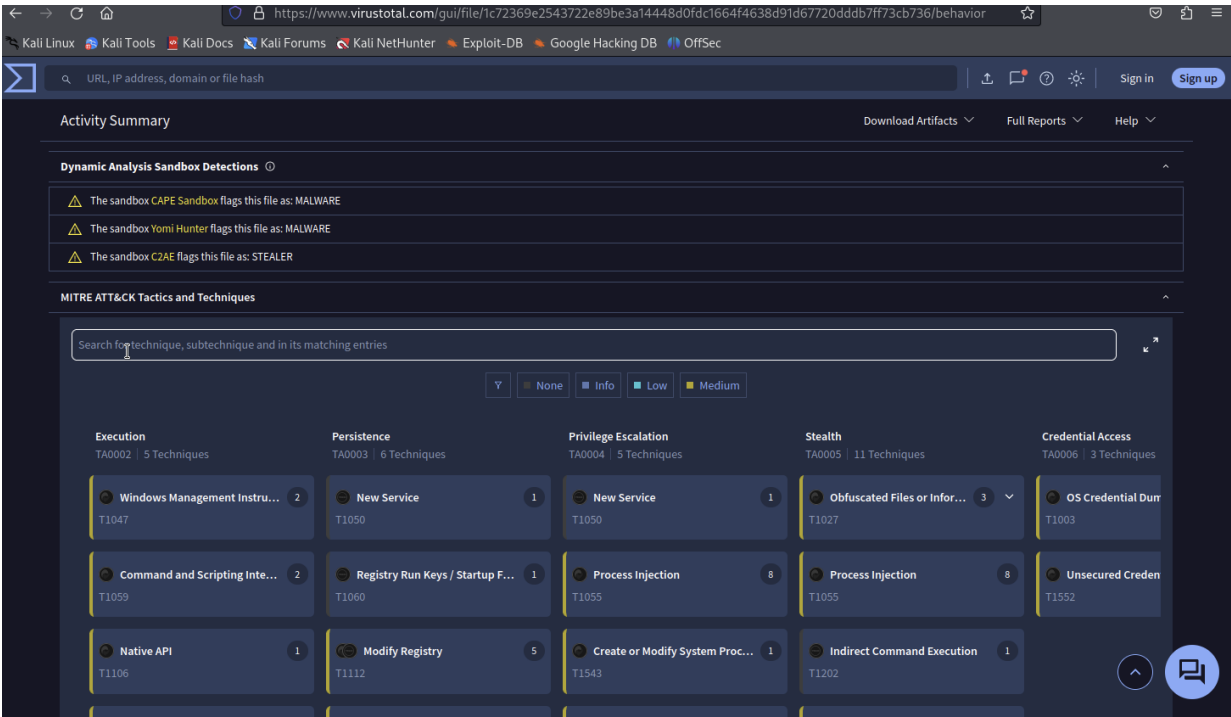
Appendix A: Evidence Screenshots

Captured from VirusTotal (sample analysis session) and the Kali Linux analysis VM. Referenced under evidence IDs EVID-Week2-Day4-001 through 008.

EVID-Week2-Day4-001 — Kali Linux VM environment with VirusTotal sample page open (analysis context)



EVID-Week2-Day4-002 — VirusTotal Behavior tab — Dynamic Analysis Sandbox Detections and MITRE ATT&CK; Tactics/Techniques overview



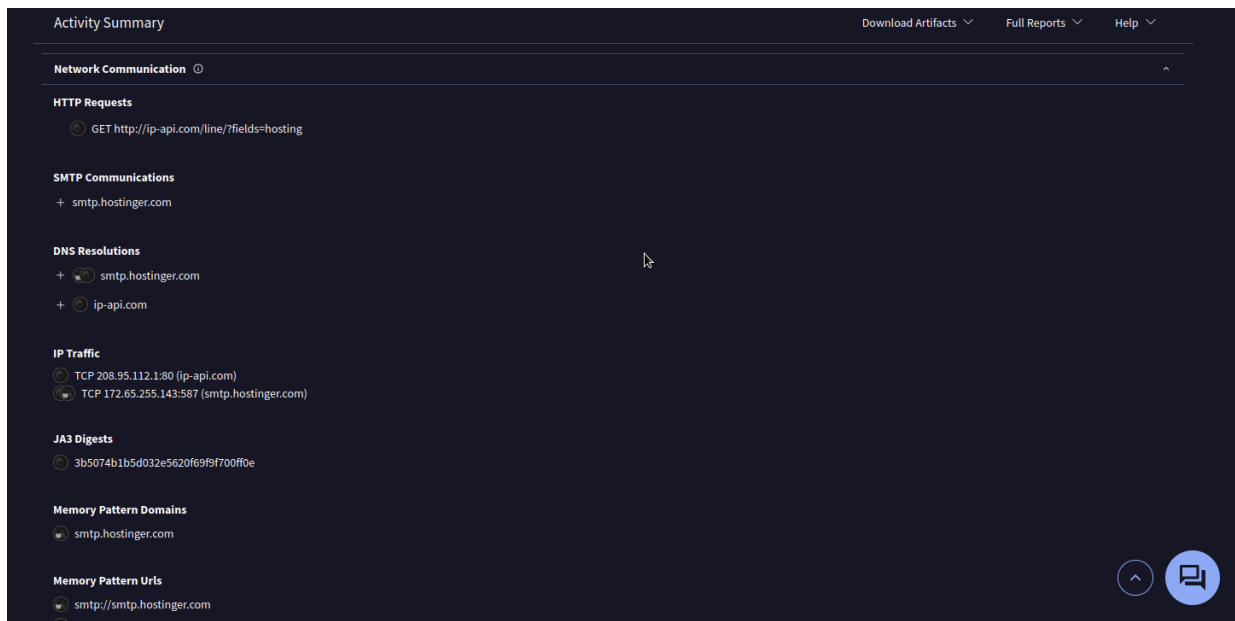
EVID-Week2-Day4-003 — VirusTotal Behavior tab — Crowdsourced IDS rules and Network Communication (HTTP/SMTP/DNS)

The screenshot shows the VirusTotal Behavior tab for a file. The interface is dark-themed. At the top, there's a search bar and navigation links. Below the search bar, the 'Activity Summary' section is visible. Under 'Crowdsourced IDS rules', there are five rules listed with their severity levels (HIGH 1, MEDIUM 2, LOW 2, INFO 0). The rules are: 1. Matches rule ET MALWARE Common Stealer Behavior - Source IP Associated with Hosting Provider Check via ip-api.com at Proofpoint Emerging Threats Open (A Network Trojan was detected). 2. Matches rule ET INFO External IP Lookup Domain in DNS Lookup (ip-api.com) at Proofpoint Emerging Threats Open (Device Retrieving External IP Address Detected). 3. Matches rule ET POLICY External IP Lookup ip-api.com at Proofpoint Emerging Threats Open (Device Retrieving External IP Address Detected). 4. Matches rule (tcp) experimental TCP options found at Snort registered user ruleset (protocol-command-decode). 5. Matches rule SURICATA Applayer Detect protocol only one direction at Suricata (Generic Protocol Command Decode). Below the IDS rules, the 'Network Communication' section is visible, showing 'HTTP Requests' (GET http://ip-api.com/line/?fields=hosting), 'SMTP Communications' (smtp.hostinger.com), and 'DNS Resolutions' (smtp.hostinger.com).

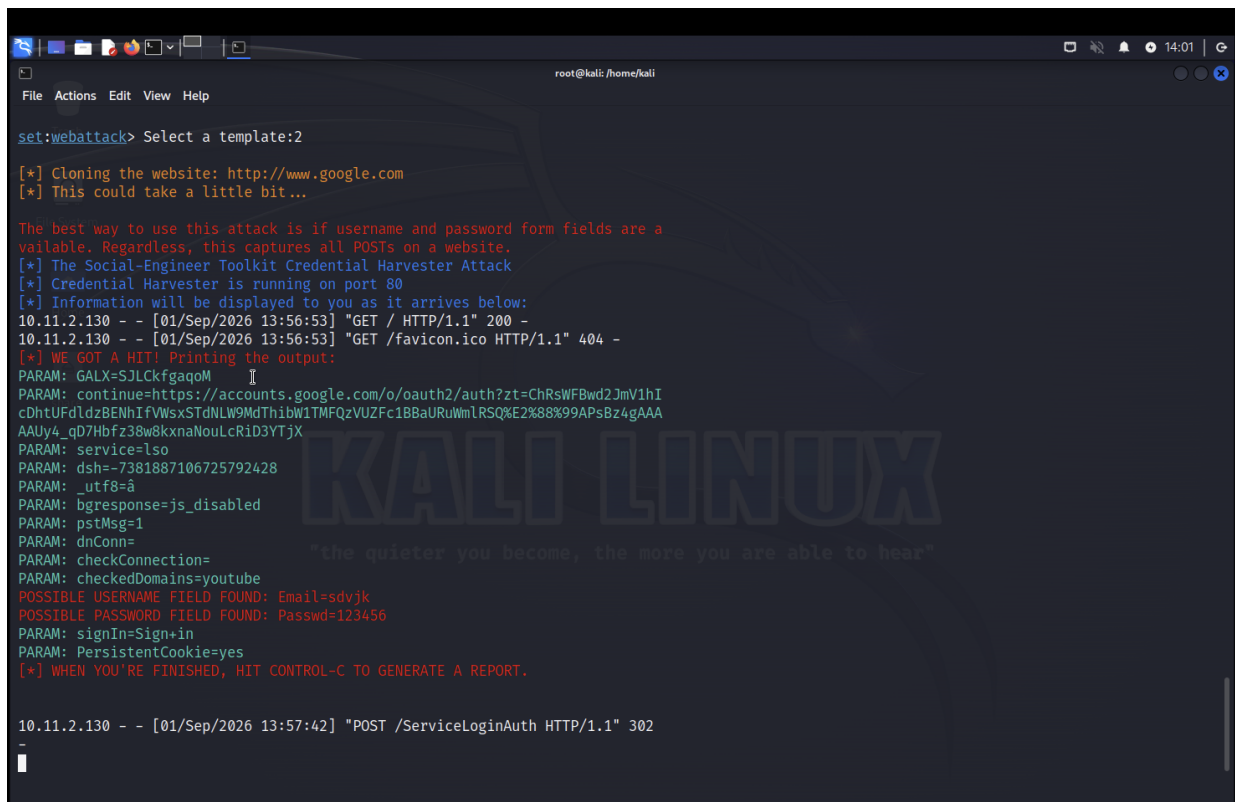
EVID-Week2-Day4-004 — VirusTotal Behavior tab — Crowdsourced Sigma Rules (registry/LSASS/DNS detections) and IDS rules detail

The screenshot shows the VirusTotal Behavior tab for a file, focusing on 'Crowdsourced Sigma Rules'. The interface is dark-themed. At the top, there's a search bar and navigation links. Below the search bar, the 'Activity Summary' section is visible. Under 'Crowdsourced Sigma Rules', there are five rules listed with their severity levels (CRITICAL 0, HIGH 0, MEDIUM 5, LOW 0). The rules are: 1. Matches rule CurrentVersion Autorun Keys Modification by Victor Sergeev, Daniil Yugoslavskiy, Gleb Sukhodolskiy, Timur Zinniatullin, oscd.community, Tim Shelton, frack113 (split) at Sigma Integrated Rule Set (GitHub) (Detects modification of autostart extensibility point (ASEP) in registry). 2. Matches rule Suspicious PowerShell In Registry Run Keys by frack113, Florian Roth (Nextron Systems) at Sigma Integrated Rule Set (GitHub) (Detects potential PowerShell commands or code within registry run keys). 3. Matches rule Suspicious DNS Query for IP Lookup Service APIs by Brandon George (blog post), Thomas Patzke at Sigma Integrated Rule Set (GitHub) (Detects DNS queries for IP lookup services such as "api.ipify.org" originating from a non browser process). 4. Matches rule Unsigned Image Loaded Into LSASS Process by Teymur Kheirkhabarov, oscd.community at Sigma Integrated Rule Set (GitHub) (Loading unsigned image (DLL, EXE) into LSASS process). 5. Matches rule Sysmon File Executable Creation Detected by frack113 at Sigma Integrated Rule Set (GitHub) (Triggers on any Sysmon "FileExecutableDetected" event, which triggers every time a PE that is monitored by the config is created). Below the Sigma Rules, the 'Crowdsourced IDS rules' section is visible, showing the same five rules as in the previous screenshot.

EVID-Week2-Day4-005 — VirusTotal Behavior tab — Network Communication detail: IP Traffic, JA3 digest, Memory Pattern Domains



EVID-Week2-Day4-006 — SEToolkit Credential Harvester — captured POST to /ServiceLoginAuth showing harvested username/password fields



EVID-Week2-Day4-007 — MITRE ATT&CK; Orangeworm (G0071) group page — profile and Techniques Used (T1071.001, T1021.002)

← → ↻ 🏠 <https://attack.mitre.org/groups/G0071/> ☆ 📧 📁 ☰

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

MITRE | ATT&CK® Matrices ▾ Tactics ▾ Techniques ▾ Defenses ▾ CTI ▾ Resources ▾ Benefactors Contribute Blog 🔗 Search 🔍

GROUPS

- OilRig
- Orangeworm**
- Patchwork
- PittyTiger
- PLATINUM
- Play
- POLONIUM
- Poseidon Group
- PROMETHIUM
- Putter Panda
- Rancor
- RedCurl
- RedEcho
- Rocke
- RTM
- Saint Bear
- Salt Typhoon
- Sandworm Team

Orangeworm

Orangeworm is a group that has targeted organizations in the healthcare sector in the United States, Europe, and Asia since at least 2015, likely for the purpose of corporate espionage.^[1]

Reverse engineering of Kwampirs, directly associated with Orangeworm activity, indicates significant functional and development overlaps with Shamoon.^[2]

ID: G0071

Contributors: Elger Vinicius S. Rodrigues, @elgervinicius, CYBINT Centre

Version: 2.0

Created: 17 October 2018

Last Modified: 31 July 2026

[Version Permalink](#)

Techniques Used ATT&CK® Navigator Layers ▾

Domain	ID	Name	Use
Enterprise	T1071 .001	Application Layer Protocol: Web Protocols	Orangeworm has used HTTP for C2. ^[3]
Enterprise	T1021 .002	Remote Services: SMB/Windows Admin Shares	Orangeworm has copied its backdoor across open network shares, including ADMIN\$, C\$WINDOWS, D\$WINDOWS, and E\$WINDOWS. ^[1]

Software

ID	Name	References	Techniques
S0099	Arp	[1]	Remote System Discovery, System Network Configuration Discovery

EVID-Week2-Day4-008 — MITRE ATT&CK; Orangeworm (G0071) Software section — Kwampirs (S0236) and supporting tools

← → ↻ 🏠 <https://attack.mitre.org/groups/G0071/> ☆ 📧 📁 ☰

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

MITRE | ATT&CK® Matrices ▾ Tactics ▾ Techniques ▾ Defenses ▾ CTI ▾ Resources ▾ Benefactors Contribute Blog 🔗 Search 🔍

GROUPS

- OilRig
- Orangeworm**
- Patchwork
- PittyTiger
- PLATINUM
- Play
- POLONIUM
- Poseidon Group
- PROMETHIUM
- Putter Panda
- Rancor
- RedCurl
- RedEcho
- Rocke
- RTM
- Saint Bear
- Salt Typhoon
- Sandworm Team

Software

ID	Name	References	Techniques
S0099	Arp	[1]	Remote System Discovery, System Network Configuration Discovery
S0106	cmd	[1]	Command and Scripting Interpreter: Windows Command Shell, File and Directory Discovery, Indicator Removal: File Deletion, Ingress Tool Transfer, Lateral Tool Transfer, System Information Discovery
S0100	ipconfig	[1]	System Network Configuration Discovery
S0236	Kwampirs	[1]	Account Discovery: Local Account, Create or Modify System Process: Windows Service, Deobfuscate/Decode Files or Information, Fallback Channels, File and Directory Discovery, Ingress Tool Transfer, Masquerading: Masquerade Task or Service, Network Share Discovery, Obfuscated Files or Information: Encrypted/Encoded File, Obfuscated Files or Information: Binary Padding, Password Policy Discovery, Permission Groups Discovery: Domain Groups, Permission Groups Discovery: Local Groups, Process Discovery, Remote Services: SMB/Windows Admin Shares, Remote System Discovery, System Binary Proxy Execution: Rundll32, System Information Discovery, System Network Configuration Discovery, System Network Connections Discovery, System Owner/User Discovery, System Service Discovery
S0039	Net	[1]	Account Discovery: Domain Account, Account Discovery: Local Account, Account Manipulation: Additional Local or Domain Groups, Create Account: Local Account, Create Account: Domain Account, Indicator Removal: Network Share Connection Removal, Network Share Discovery, Password Policy Discovery, Permission Groups Discovery: Domain Groups, Permission Groups Discovery: Local Groups, Remote Services: SMB/Windows Admin Shares, Remote System Discovery, System Network Connections Discovery, System Service Discovery, System Services: Service Execution, System Time Discovery